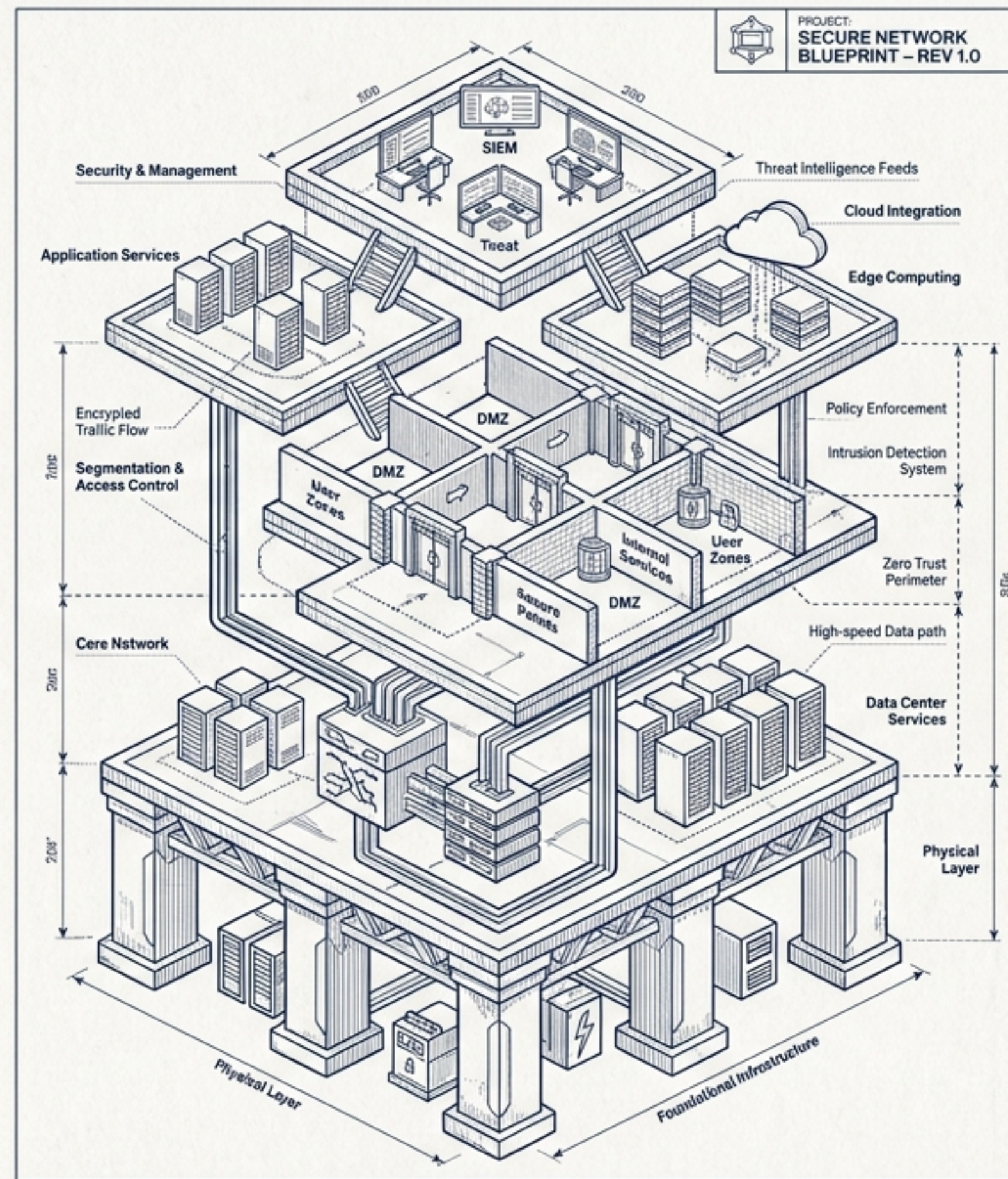


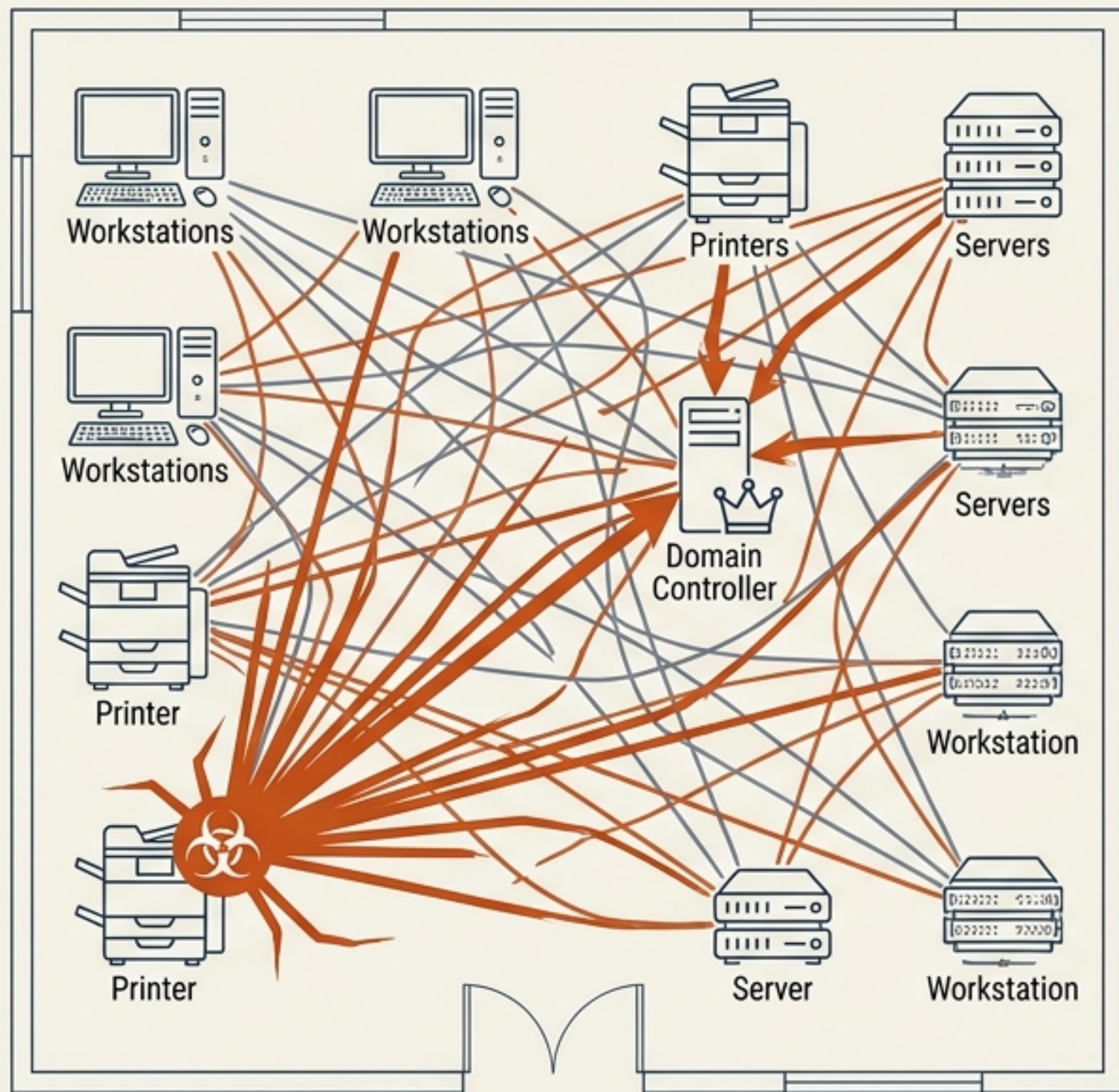
# Anatomy of a Secure Network

The Architect's Blueprint for Design, Segmentation, and Defense



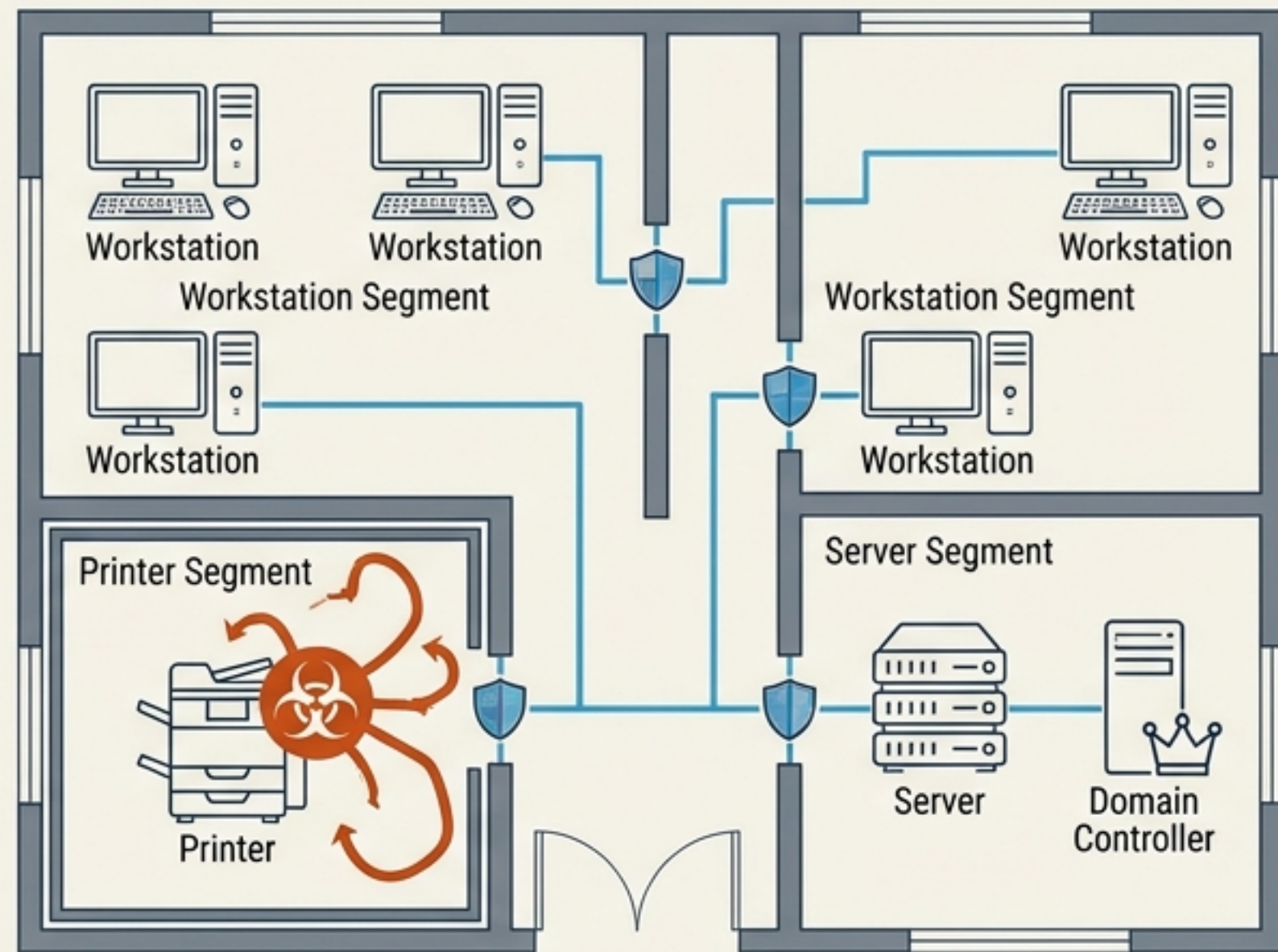


# The Flat Network



Zero separation. Operational but entirely insecure.  
A single breach compromises everything.

# Segmented Defense-in-Depth



Limits lateral movement.  
Makes suspicious pivoting highly visible.

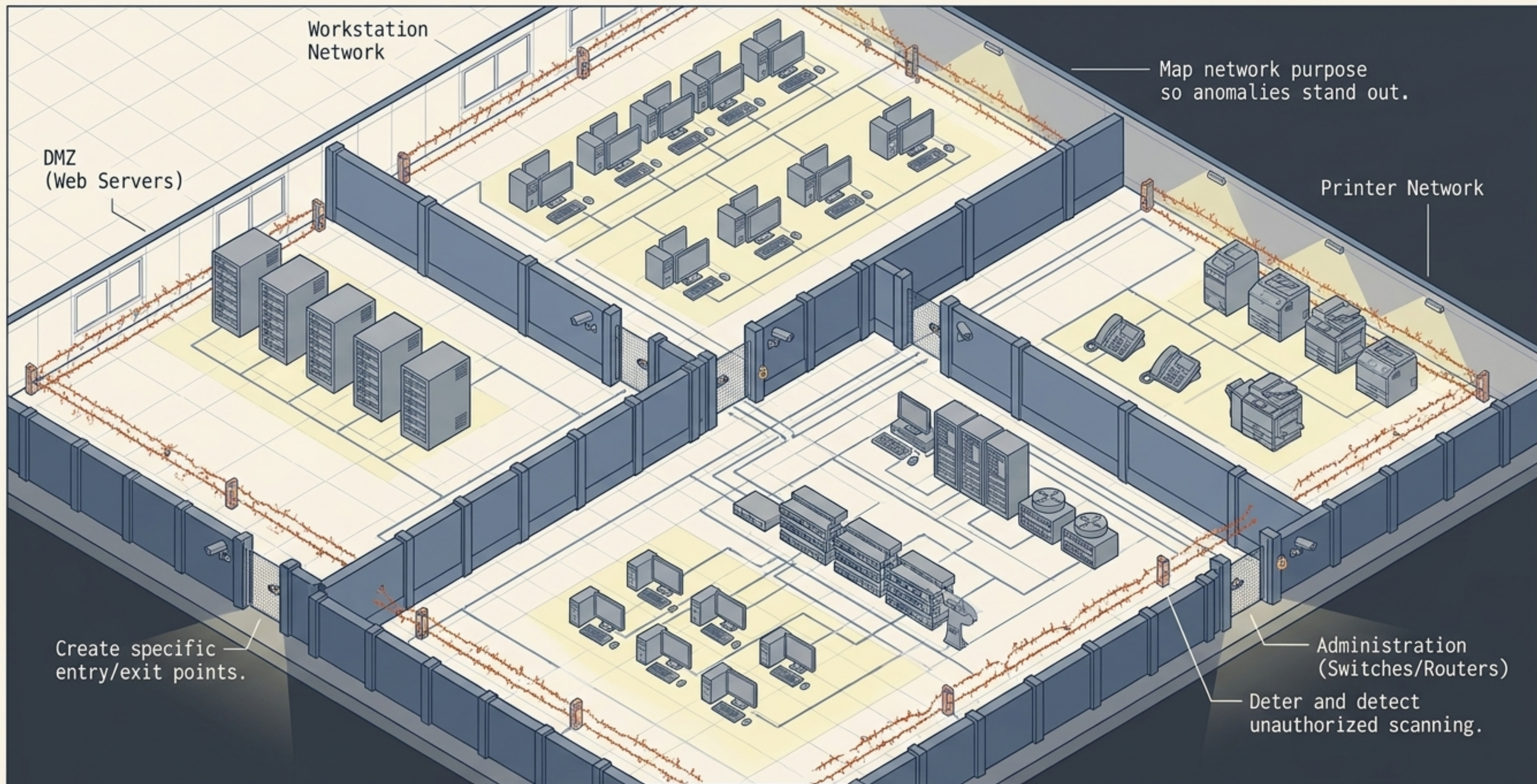
## Real-World Threat: The COVID Printer Breach

A pen-tester mailed a compromised printer to a target. It bypassed security because:

1. Workstations could talk to the printer (port 445).
2. The printer could initiate connections back.
3. The printer had unrestricted internet access.

Proper segmentation neutralizes all three vectors. 🔒 🚫



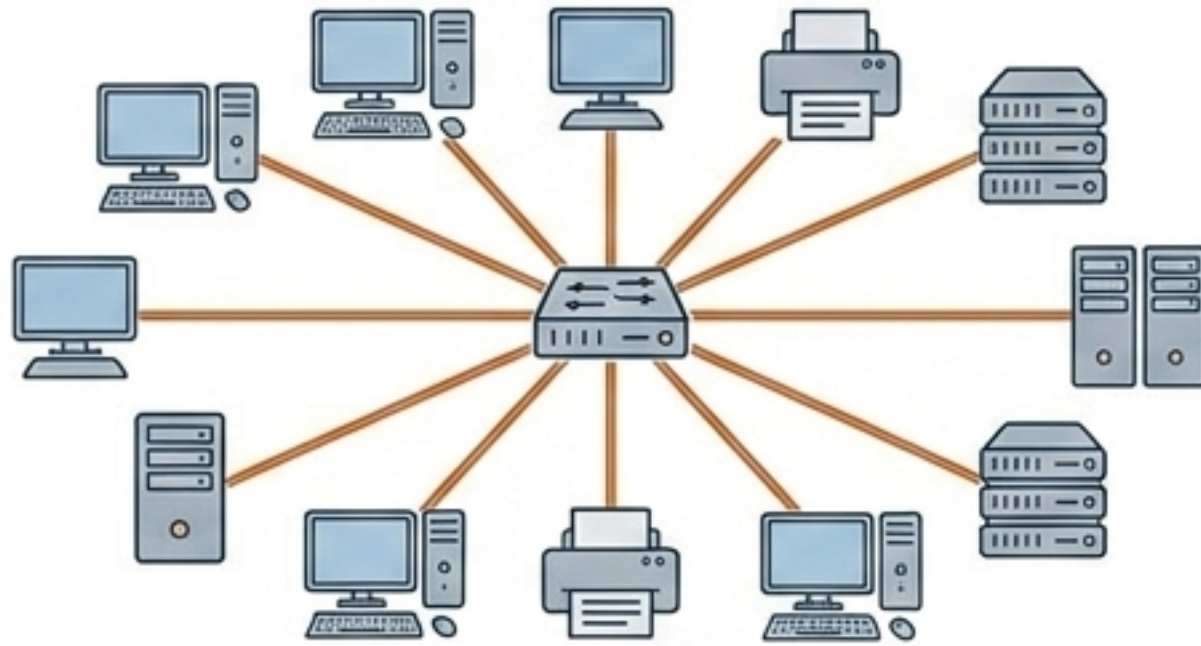


**Key Insight:** Keep Administration networks isolated to prevent workstation snooping. Isolate Printers, as they easily leak NTLMv2 credentials.



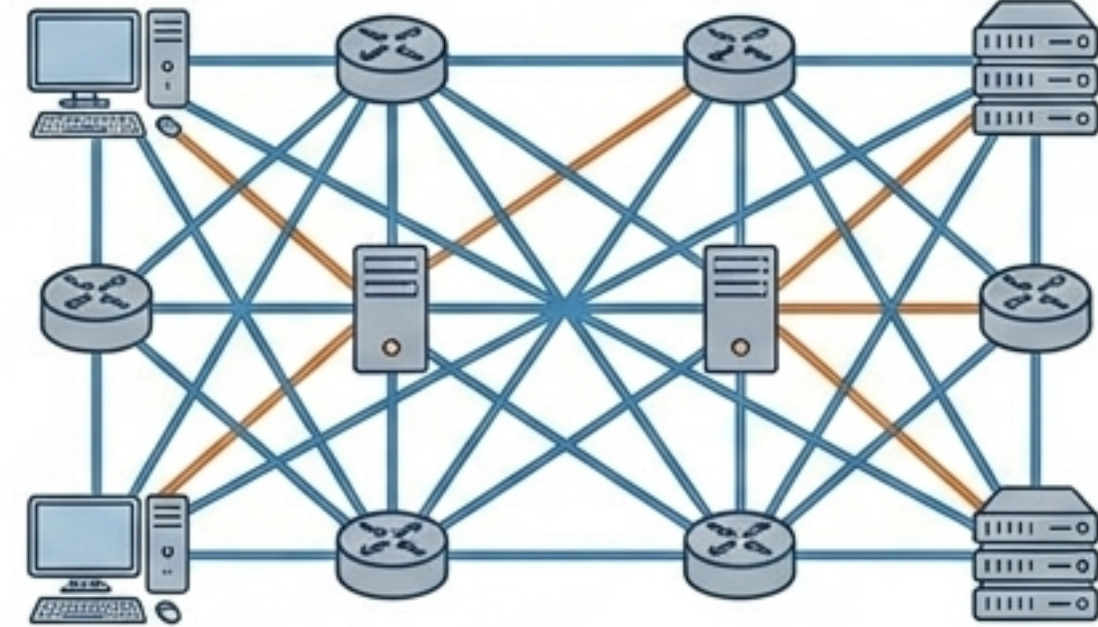
# Physical & Logical Topologies

## Star Topology



**Most Common (LANs).**  
All hosts connect to one central device.

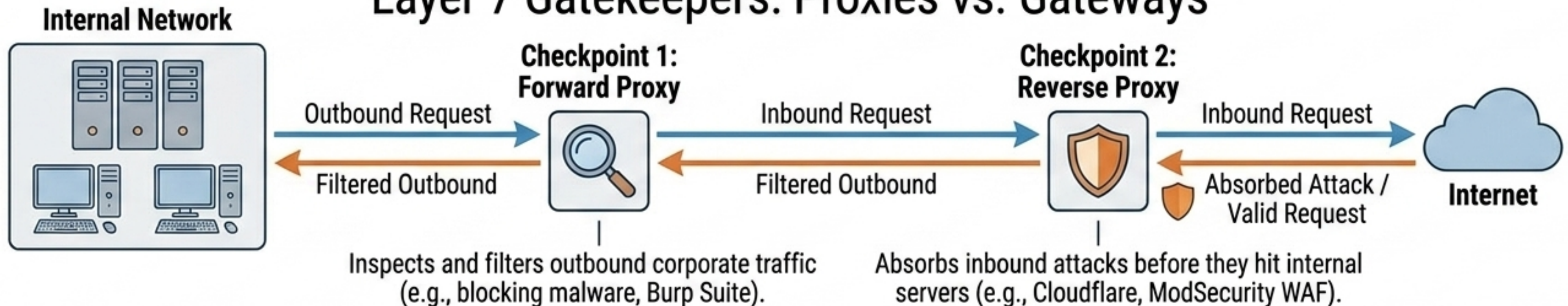
## Mesh Topology



**Highest Redundancy (WANs/MANs).**  
Hosts connect to multiple others.

Note: Real networks are Hybrids.

## Layer 7 Gatekeepers: Proxies vs. Gateways





# The Theoretical Frameworks: OSI vs. TCP/IP

## Focus: Granularity & Analysis

- 7 strict layers.
- Used by pen-testers to intercept, dissect, and analyze packets layer by layer.
- Each layer only talks directly to the one above or below it.

### The OSI Model

7. Application

6. Presentation

5. Session

4. Transport

Network

Data-Link

Physical

### The TCP/IP Model

4. Application

3. Transport

2. Internet

1. Link

## Focus: Practicality & Implementation

- 4 flexible layers.
- The actual functional basis of internet communication.
- Used to quickly grasp how a connection is practically established.

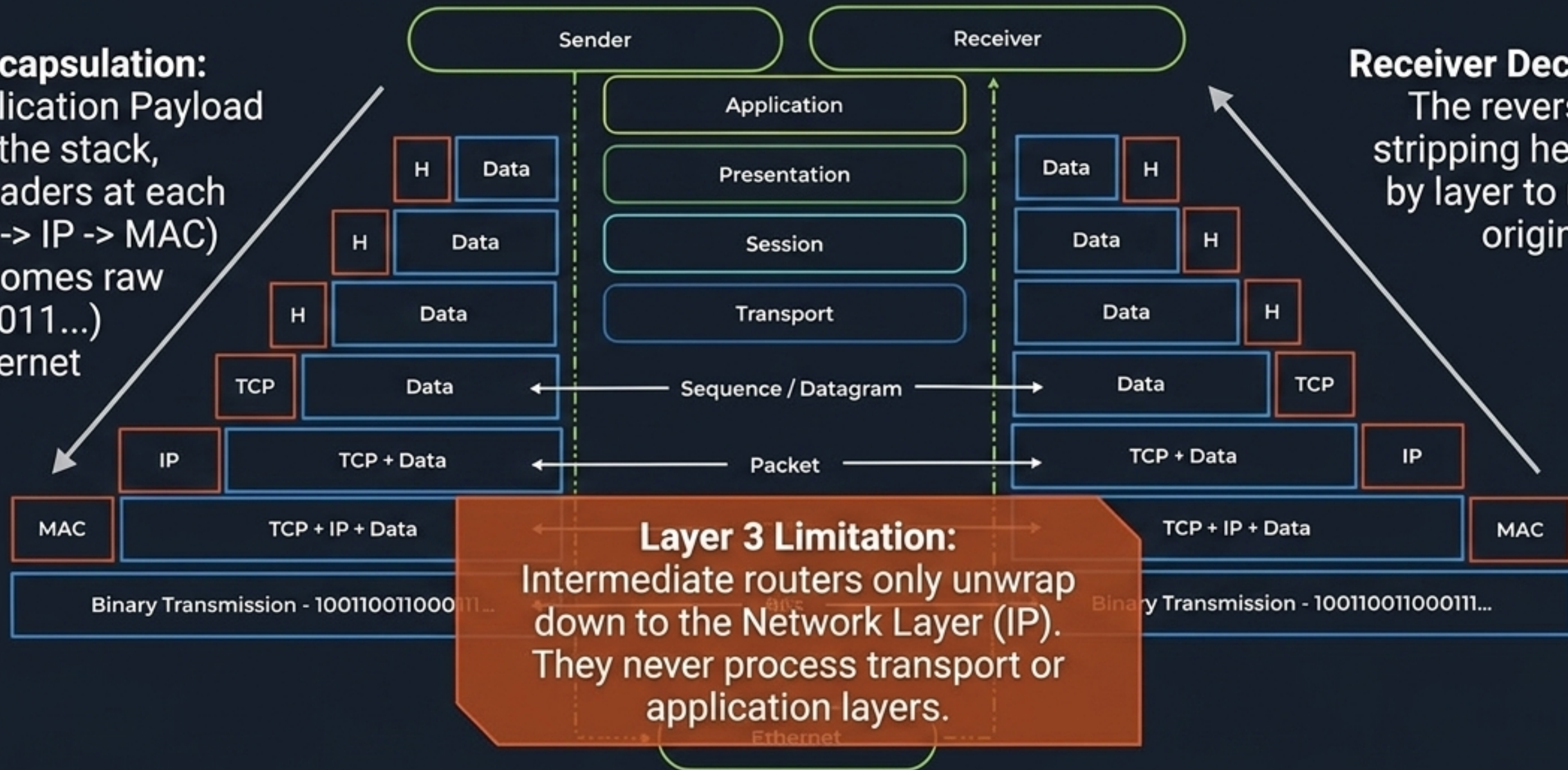
**IP (Addressing/Routing) + TCP (Reliability/Flow Control) = The foundation of the internet.**  
**Know OSI to break it apart; know TCP/IP to build it.**



# The Encapsulation Russian Doll

## Sender Encapsulation:

A raw Application Payload descends the stack, gaining headers at each step (TCP -> IP -> MAC) until it becomes raw Binary (10011...) on the Ethernet medium.



## Receiver Decapsulation:

The reverse process, stripping headers layer by layer to retrieve the original payload.



# The Addressing Diagnostic

| Layer 2: MAC Address                                                                                                                                                                                                                                                                                 | Layer 3: IPv4                                                                                                                                                                                                                                                                                            | Layer 3: IPv6                                                                                                                                                                                                                                                                                                    |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>• <b>Scope:</b> Local (Floor &amp; Apartment)</li><li>• <b>Format:</b> 48-bit Hexadecimal</li><li>• <b>Example:</b><br/>"DE:AD:BE:EF:13:37"</li><li>• <b>Traits:</b> Identifies device in a LAN. Easily spoofed. First 3 bytes = OUI (Manufacturer).</li></ul> | <ul style="list-style-type: none"><li>• <b>Scope:</b> Global (Postal Address)</li><li>• <b>Format:</b> 32-bit Decimal</li><li>• <b>Example:</b><br/>"192.168.10.39"</li><li>• <b>Traits:</b> Requires NAT. Divided into Network part and Host part via Subnet Mask. Exhausted at ~4.3 billion.</li></ul> | <ul style="list-style-type: none"><li>• <b>Scope:</b> Global (The Future)</li><li>• <b>Format:</b> 128-bit Hexadecimal</li><li>• <b>Example:</b><br/>"fe80::dd80:b1a9:6687:2d3b"</li><li>• <b>Traits:</b> No NAT needed. Mandatory IPsec. Replaces broadcast with multicast. SLAAC self-configuration.</li></ul> |



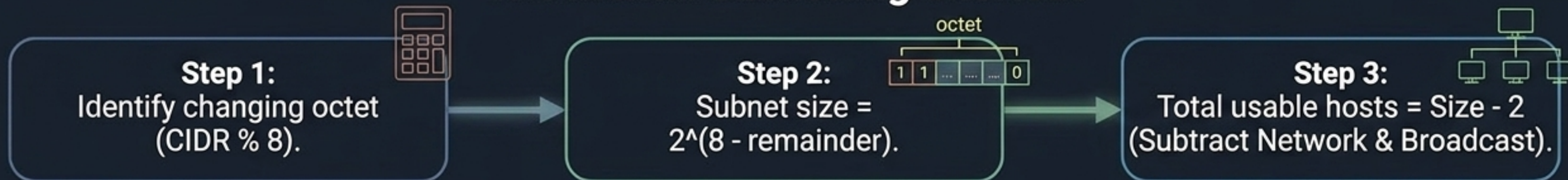
# The Addressing Diagnostic

**The /24 vs /25 Subnet Mistake**  
A pen-tester assumed a standard /24 subnet and missed the Domain Controller entirely because the network used a /25 (dividing the range in half). They reported the DC offline when it was just unreachable.

## The Subnet Slider



## The Mental Subnetting Shortcut





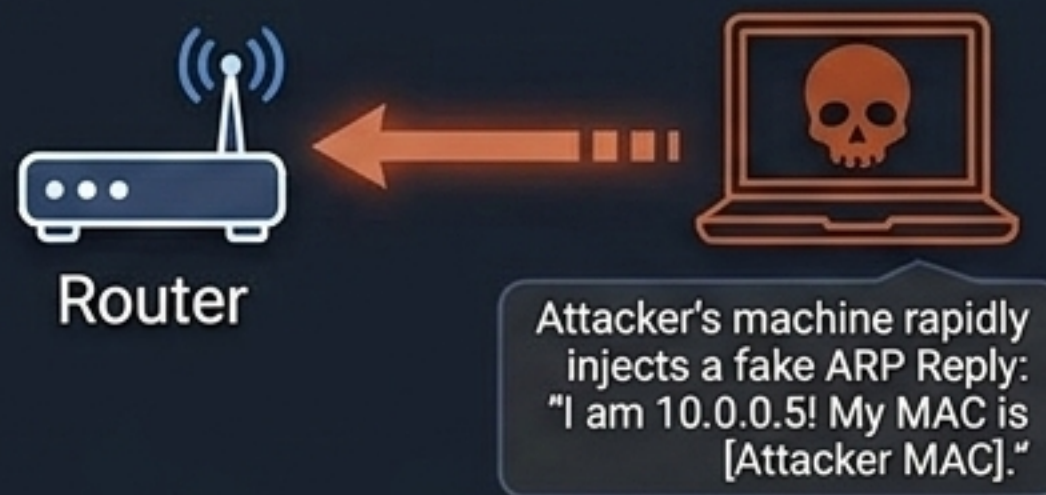
# The Vulnerability of Trust: Layer 2 Attacks

## The Request



Router sends a broadcast:  
"Who has IP 10.0.0.5?  
Tell me your MAC."

## The Poisoning



Attacker's machine rapidly  
injects a fake ARP Reply:  
"I am 10.0.0.5! My MAC is  
[Attacker MAC]."

## The Interception



Data flows are re-routed.  
Victim and router now send  
all traffic through the  
attacker (MITM).

ARP has no authentication. MAC addresses can be spoofed.  
Mitigate with IPSec, SSL, and rigid network segmentation.



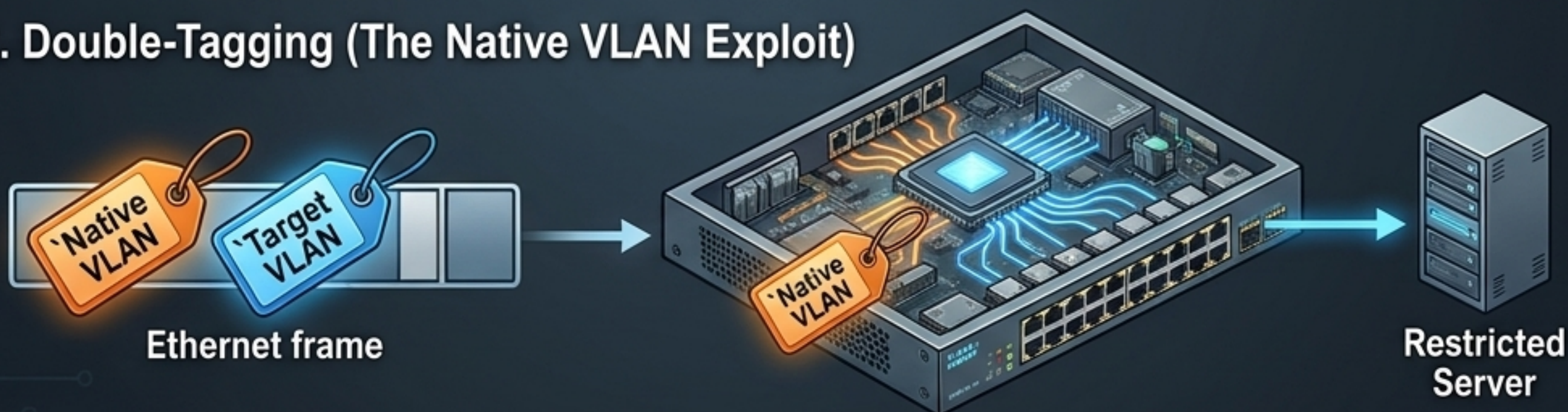
# Bypassing Fences: The Anatomy of VLAN Hopping

## 1. DTP Hopping (Trunk Exploitation)



Fix: Disable 'DTP' on all non-trunk ports.

## 2. Double-Tagging (The Native VLAN Exploit)

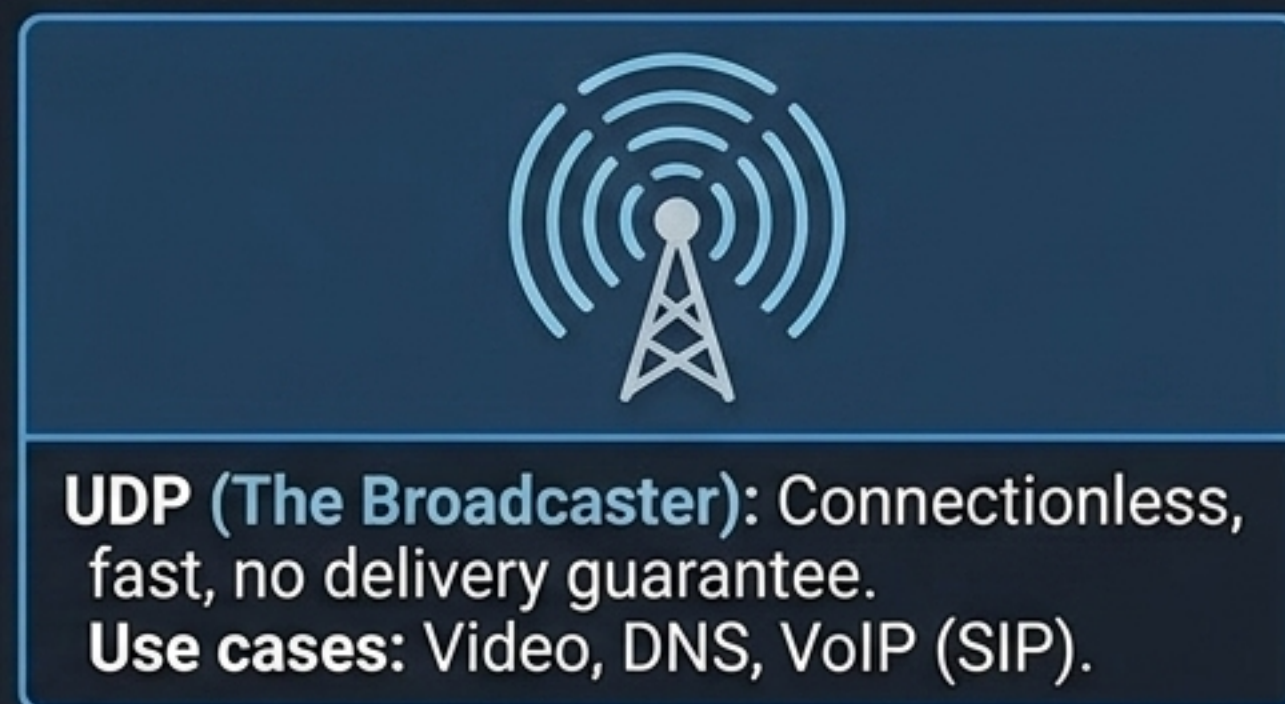
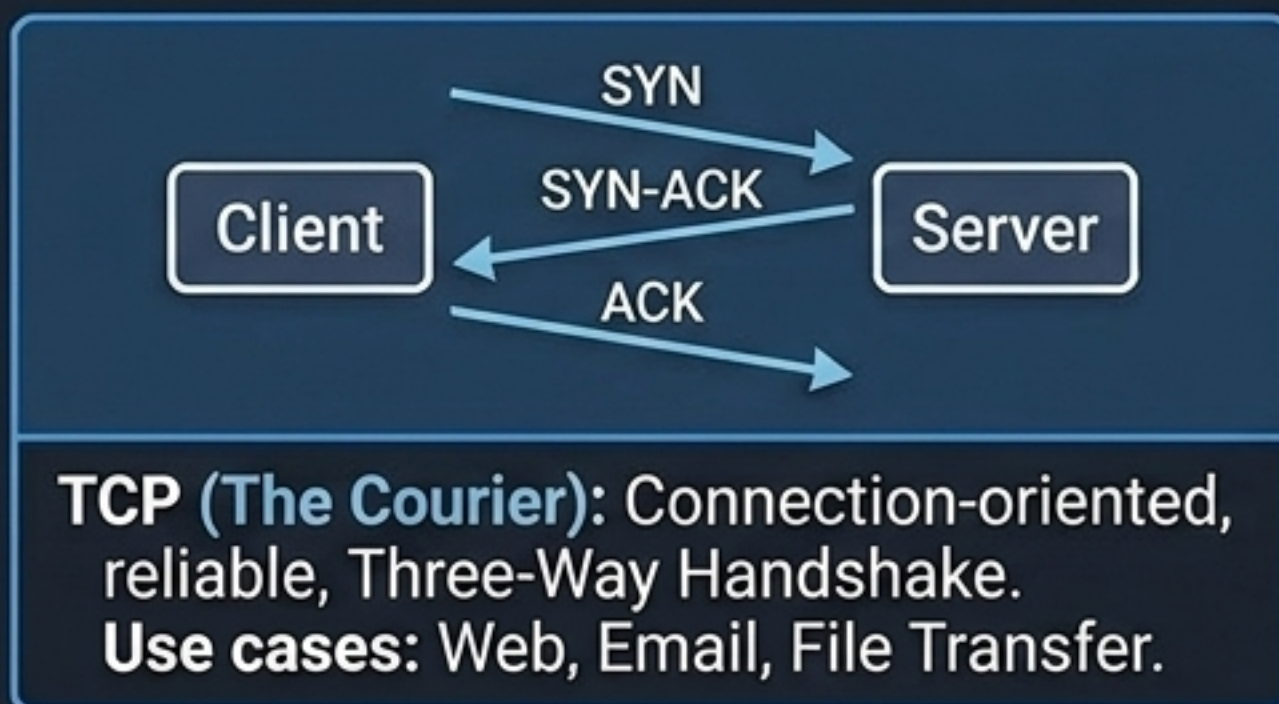


Mechanism: First switch reads and strips the outer 'Native' tag. The frame is forwarded with the inner tag intact, tricking the next switch into delivering it to the restricted 'Target VLAN'.



# Layer 4 Traffic Laws: TCP vs. UDP

## The Protocol Showdown



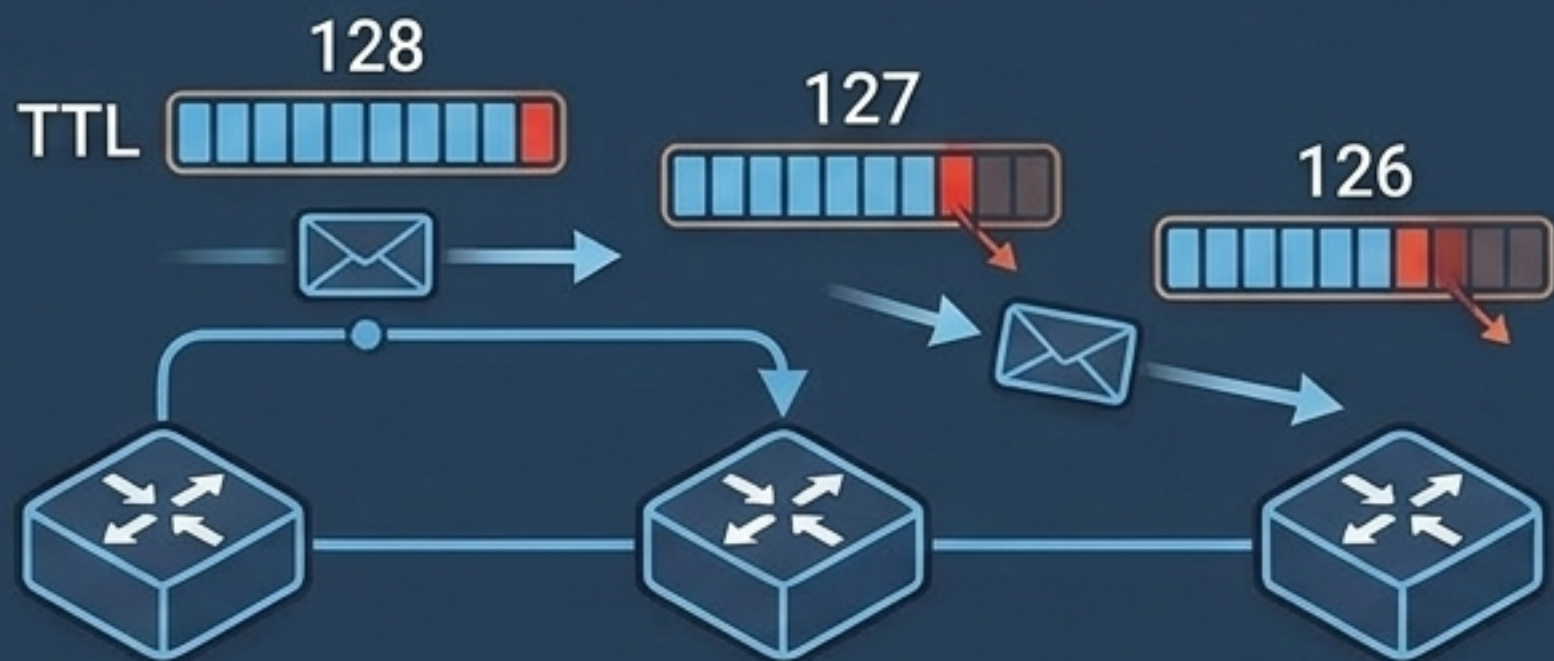
## The Port Cheat Sheet

|   |             |        |        |       |   |                    |         |            |             |
|---|-------------|--------|--------|-------|---|--------------------|---------|------------|-------------|
| 1 | Remote/File |        |        |       | 2 | Web/Auth           |         |            |             |
|   | 22          | 21     | 3389   | 445   |   | 80                 | 443     | 88         | 389         |
|   | (SSH)       | (FTP)  | (RDP)  | (SMB) |   | (HTTP)             | (HTTPS) | (Kerberos) | (LDAP)      |
| 3 | Email       |        |        |       | 4 | Infrastructure/UDP |         |            |             |
|   | 25          | 110    | 143    |       |   | 53                 | 67/68   | 161        | 500         |
|   | (SMTP)      | (POP3) | (IMAP) |       |   | (DNS)              | (DHCP)  | (SNMP)     | (IKE/IPsec) |



# Network Diagnostics & Fingerprinting

## ICMP & TTL (Time To Live)



### OS Fingerprinting

### Default TTL

Windows

128

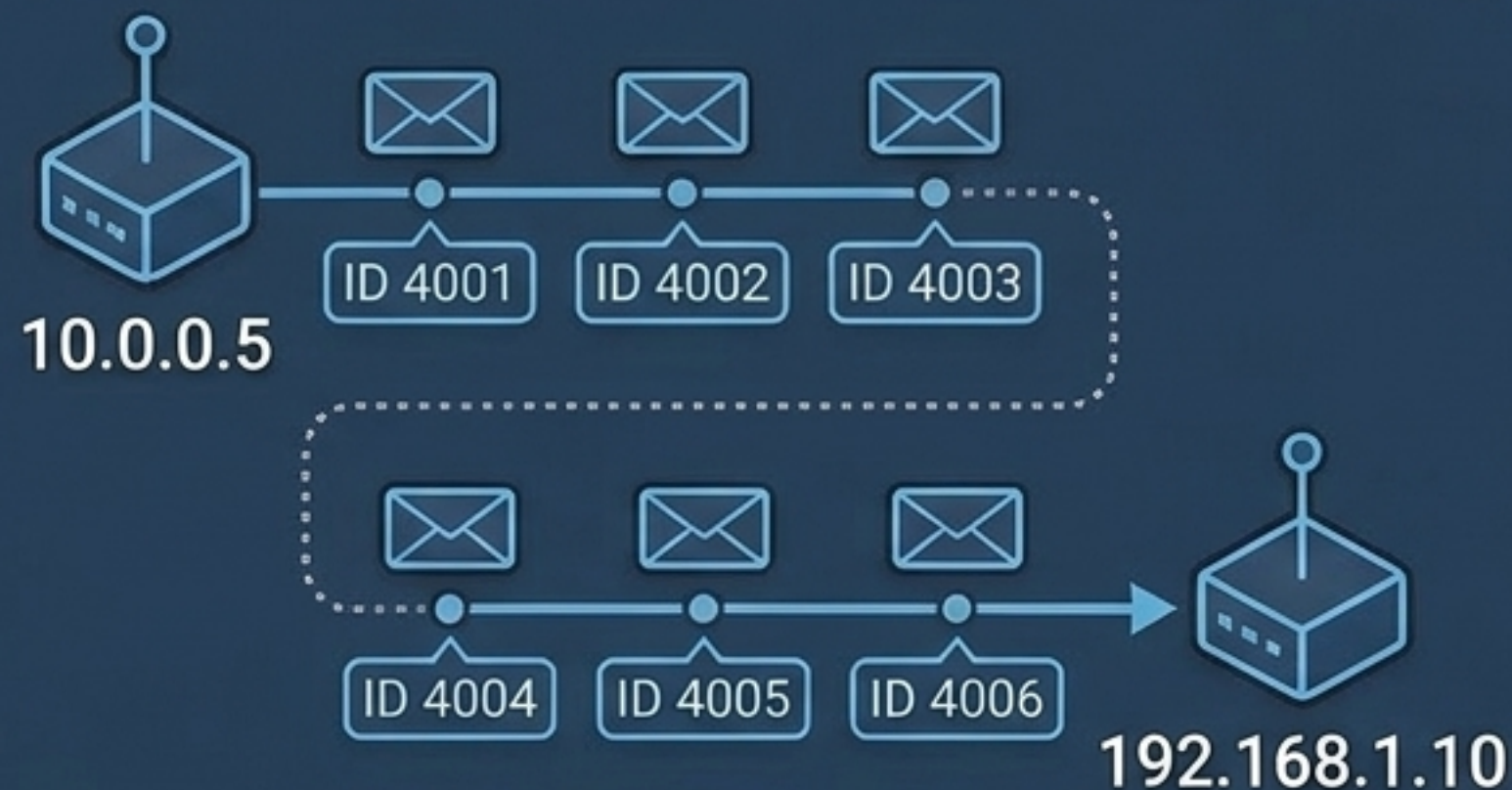
Linux/macOS

64

Solaris

255

## IP ID Blind Spoofing



Sequential IP IDs strongly indicate both IPs belong to the same physical host, allowing attackers to track targets using multiple addresses.



# Deploying External Security: Wireless & VPNs



## Wireless Perimeter



**WEP & LEAP:** Broken.  
Vulnerable to dictionary attacks and IV brute forcing.



**WPA2/WPA3:** Modern standards (AES minimum).  
WPA3 for critical infrastructure.



**EAP-TLS:** The Gold Standard.  
Uses digital certificates and PKI on both client and server.



## VPN & IPsec Tunnels

Creates an encrypted tunnel giving remote devices an internal IP over public internet.

- **Transport Mode:** Encrypts payload only (host-to-host).
- **Tunnel Mode:** Encrypts entire IP packet + header (VPN standard).
- **Protocols:** ESP (encryption) via UDP/4500 (NAT traversal) + IKEv2 (Key exchange via UDP/500).



**Avoid PPTP:** Relies on weak DES encryption.



# The Cryptography Vault

## Algorithms: Symmetric vs. Asymmetric



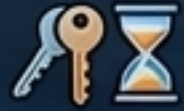
### Symmetric:

Same key encrypts/decrypts. Fast.  
**Challenge:** Key Distribution.  
**Standard:** AES (128/256-bit).



### Asymmetric:

Public encrypts / Private decrypts.  
Solves key distribution, slower.  
**Standards:** RSA (primes) & ECC (elliptic curves).



## Key Exchange

**Focus:** Diffie-Hellman (DH) & Elliptic Curve DH (ECDH).



**Forward Secrecy:** ECDH ensures past communications remain secure even if private keys are compromised later.

## Cipher Modes

### Avoid:



**ECB** (Encrypts blocks independently, reveals visual patterns).



### Standard:



**AES-CBC** (Chained blocks, standard for disk/TLS).



### Best:

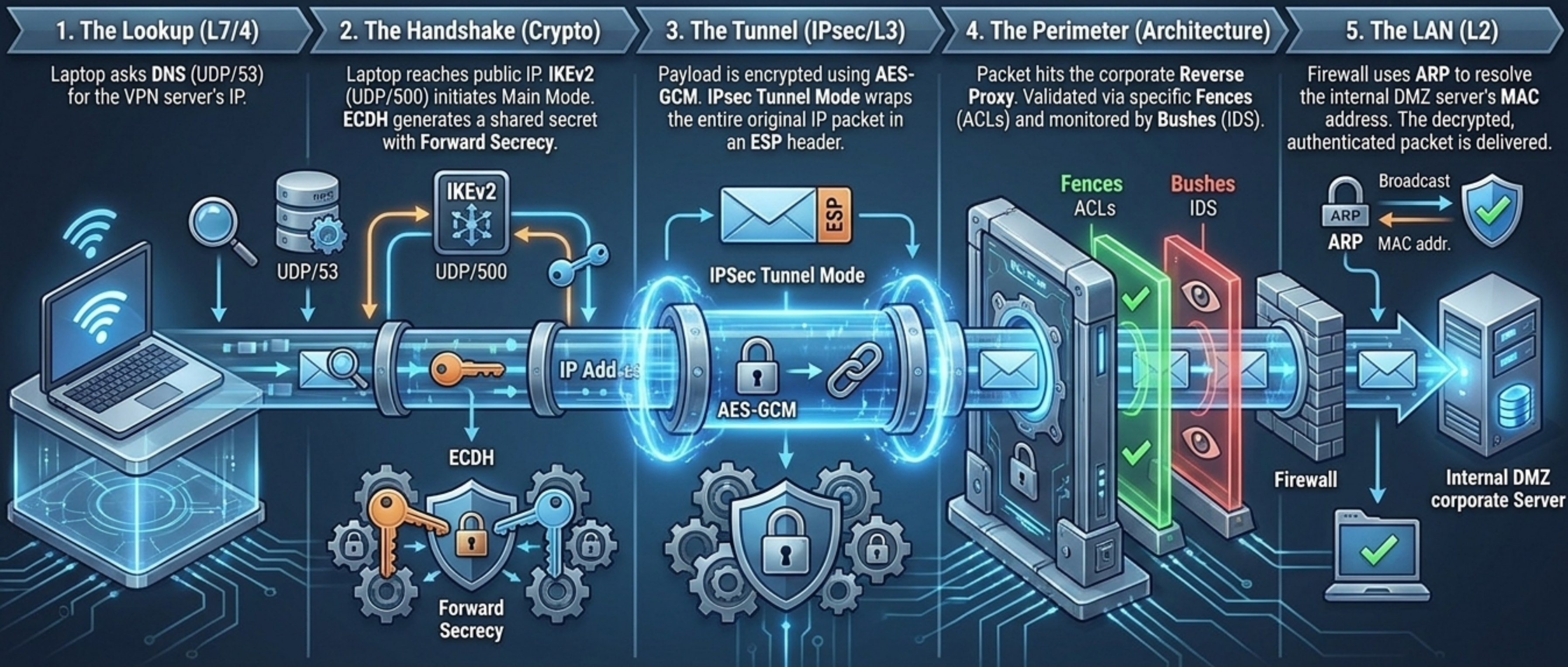


**GCM** (Provides both confidentiality AND integrity. Ideal for VPNs).





# The Symphony of the Stack: Lifecycle of a Secure Packet



From raw binary to encrypted application data, every layer serves a purpose. Architecture is defense.